CASE STUDY

Ghostcat, CVE-2020-1938: The Tomcat AJP File Read in the Lab

A TeamStarWolf case study. Published 4 November 2026; every source checked as of that date.

Executive summary

Apache Tomcat serves Java web applications, and until February 2020 it shipped with a second front door next to its HTTP port. A stock Tomcat opened an AJP/1.3 connector on port 8009, meant for a reverse proxy such as Apache httpd to forward requests over a binary protocol. Before the February 2020 fixes, that connector was enabled by default and listened on every configured address, and Tomcat trusts an AJP connection more than an HTTP one (Confirmed [1][2][3]). A researcher at Chaitin Tech found, and on 3 January 2020 reported to Apache, that the trust went far enough for anyone who could reach port 8009 to make Tomcat return any file in a web application, including the protected `WEB-INF` and `META-INF` folders, or to process any file in the application as a JSP (Confirmed [1][18]). Chaitin named the bug Ghostcat (Confirmed [18]).

The fix shipped quietly before the disclosure. Tomcat 9.0.31 and 8.5.51 came out on 11 February 2020 and 7.0.100 on 14 February, each switching the AJP connector off by default, binding it to loopback, requiring a shared secret and refusing unrecognised request attributes with a 403 (Confirmed [1][3][4][5][6]). China's CNVD and Chaitin published on 20 February, a public proof of concept appeared the same day, Apache made the issue public on 24 February, and mass scanning was reported within a week (Confirmed [1][18][19]; Demonstrated [38]; Reported [43][45]). CISA added CVE-2020-1938 to the Known Exploited Vulnerabilities catalog on 3 March 2022, and it was still there in the 3 November 2026 catalog (Confirmed [23]).

The lab run behind this study, on 3 November 2026, put the vulnerable and fixed builds side by side on loopback. On Tomcat 9.0.30 with its stock connector, a pinned read-only probe pulled `WEB-INF/web.xml` over AJP while the same file over HTTP returned 404. On a 9.0.31 control with AJP deliberately exposed and no secret, the same probe got `HTTP Status 403`, so the code fix, not only the new default configuration, blocks the read (Demonstrated [67][69]). The lab also found that the probe requests appear in Tomcat's access log on the fixed build (the vulnerable build's log was not checked), which corrects the lab plan's own expectation

(Demonstrated [69]).

> Evidence grade: the flaw, the affected and fixed versions, the fix and the KEV listing are **Confirmed** from Apache, Chaitin's archived disclosure, CNVD, NVD, the CVE record and CISA. The file read, the 403 on the fixed build and the access-log finding are **Demonstrated** in the lab. Scanning counts and the 2026 activity reports are **Reported**. No opened source names a threat actor that used Ghostcat; where this study draws its own conclusion, it is labelled **Inferred**.

Key facts at a glance

Field	Value
Identifier	CVE-2020-1938, "Ghostcat" (Chaitin's name); CNVD-2020-10487; GitHub advisory GHSA-c9hw-wf7x-jp9j [18][19][26]
Apache title	"AJP Request Injection and potential Remote Code Execution" [1]
Product	Apache Tomcat; the embedded `org.apache.tomcat.embed:tomcat-embed-core` jar too [1][26]
What it does	Returns any file in a web application, including `WEB-INF` and `META-INF`, and processes any web-application file as a JSP; code execution needs an attacker-controlled file inside the application [1]
Affected	9.0.0.M1 to 9.0.30, 8.5.0 to 8.5.50, 7.0.0 to 7.0.99 [1][2][3]; Chaitin and CNVD also list all of 6.x, which received no upstream fix; Red Hat fixed its RHEL 6 tomcat6 package (RHSA-2020:0912) [15][18][19][27]
Fixed	9.0.31 and 8.5.51 (11 February 2020), 7.0.100 (14 February 2020) [1][2][3]
Precondition	An AJP port reachable by untrusted users; stock builds before the fix listened on all addresses [1]
CVSS 3.1	9.8 Critical, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` (NVD and CISA-ADP; the Apache CNA container carries no score) [21][22]
Vendor ratings	Apache: Important for Tomcat 9 and 8, High on its Tomcat 7 page; Red Hat: Important; Ubuntu: priority Low [1][2][3][27][29]
Weakness	No CWE assigned by NVD (`NVD-CWE-Other`); the labels differ across records (Part 1) [21][22][26][27]
Reported and public	Reported to Apache 3 January 2020; CNVD and Chaitin notices 20 February 2020; made public by Apache 24 February 2020 [1][18][19]
CISA KEV	Added 3 March 2022, due 17 March 2022, known ransomware use Unknown [23]
CISA SSVC	Exploitation active, Automatable yes, Technical Impact total (CISA ADP, 6 February 2025) [22]
EPSS	0.9927, percentile 0.99937, on 3 November 2026 [25]
Lab result	File read Demonstrated on 9.0.30; 403 on a 9.0.31 control with AJP exposed and no secret; file-read half only, no upload or code execution [65][67][69]

Key findings

- **The flaw is a trust problem on a default-on second port.** Tomcat treats AJP traffic as coming from a trusted proxy, and before the fix it opened that connector on every address by default (Confirmed [1]). Apache's own advisory says the known risks of direct AJP access had been client-IP and proxy-authentication bypasses; Ghostcat added the file return and the JSP processing (Confirmed [3][1]).
- **The read reaches what HTTP protects.** In the lab, `WEB-INF/web.xml` returned 404 over HTTP on both builds, while the AJP probe returned the file on 9.0.30 (Demonstrated [67][69]). An HTTP request for the same file showed nothing wrong, although the HTTP error page still disclosed Apache Tomcat/9.0.30 to any version check (Demonstrated [67][68]).
- **The 9.0.31 code change blocks the read even when the configuration is reopened.** The lab's control re-exposed AJP on `0.0.0.0` with `secretRequired="false"`, and the same probes got a 403 (Demonstrated [67][69]). That matches the `allowedRequestAttributesPattern` check that 9.0.31 added (Confirmed [4][7][12]; the link to the lab's 403 is Inferred).
- **Code execution is conditional.** Apache, Chaitin and Trend Micro agree that remote code execution needs a file the attacker controls inside the web application, for example an upload stored under the document root; by default the flaw is a file read (Confirmed [1][18][36]). The lab ran the read only (Demonstrated [65]).
- **Exploitation is catalogued, but no actor is named.** KEV lists the CVE, and CISA's SSVC entry says exploitation is active (Confirmed [22][23]). No opened source ties Ghostcat to a named group, campaign or malware family, and KEV marks ransomware use as Unknown (Inferred from [23][48][49]).
- **The long tail is still long.** About six years and eight months after disclosure (Inferred arithmetic), EPSS sits at 0.9927, DShield still records about 950 to 6,200 port 8009 events a day, and a 2026 count of ajp13 fingerprints passed 1.2 million (Confirmed [25][47]; Reported [53]). Tomcat 6, 7 and 8.5 are all end of life (Confirmed [15]).

Top recommendations

1. Find every Tomcat, including the ones that do not look like Tomcat: tarball installs, distribution packages, vendor-bundled copies and embedded `tomcat-embed-core` jars. Read the version from `bin/version.sh` or `bin/version.bat`, not the HTTP banner (Part 4).
2. Upgrade to a supported Tomcat line at or above the fixed release. 7.0 and 8.5 are end of life, so moving to 9.0 or later is the durable fix, and Apache warns that the hardened AJP defaults will likely need small configuration changes (Confirmed [1][2][15]).
3. If nothing uses AJP, remove or comment out the connector. If a proxy uses it, bind it to loopback or a private address, set a `secret` on both the connector and the proxy, and never set `secretRequired="false"` outside a trusted network (Confirmed [7][8][16][17]).
4. Firewall port 8009 so only the proxy can reach it, and check exposure from outside the host and inside containers, because a loopback publish can hide an all-address bind (Demonstrated [68]; Confirmed [29]).
5. Treat any host where 8009 was reachable by untrusted sources as possibly read: rotate secrets that lived in `WEB-INF` or `META-INF` files and look for unexpected files in the application folders (Inferred [1][65]).

Scope and method

This study covers CVE-2020-1938 in Apache Tomcat from its report to Apache on 3 January 2020 to the KEV catalog of 3 November 2026, and a lab run on 3 November 2026. It draws on Apache's security pages, changelogs, connector documentation and the `apache/tomcat` repository; Chaitin's and CNVD's disclosures, read from archived copies because the live pages no longer answer; the NVD, CVE, KEV, EPSS and GitHub advisory records; distribution and vendor advisories; detection content; reporting on the 2020 scanning; 2026 activity reports; the MITRE ATT&CK, CWE, CAPEC and D3FEND records and the library's data files; and the lab captures. Every source was opened on 4 November 2026.

Grade	Meaning
Confirmed	A primary source was opened: Apache, Chaitin, CNVD, NVD, the CVE record, CISA, a distribution or product vendor, a scanner or rule publisher for its own content, or the MITRE page itself
Reported	A secondary source's account, or a figure this study could not check against its origin, carried as the source states it
Demonstrated	Reproduced in the TeamStarWolf lab run of 3 November 2026 (the capture file is named), or a public reproduction exists
Inferred	This study's own reasoning from the cited facts, labelled where it appears

The lab kept to these rules: Docker targets bound to loopback, two matched images (vulnerable and fixed), third-party probes fetched at pinned commits, read in full and hashed before use, short quotes from the captures, and cleanup verified. Proof-of-concept invocations and their payloads are described in one sentence and never reproduced; version checks and the lines that differ between the two builds are shown. The screenshots are renderings of the real command output with the lab host anonymized and a neutral prompt.

Chaitin's live Ghostcat page returned 404 and `cnvd.org.cn` returned HTTP 521, so both are cited from Internet Archive copies made in March and May 2020 (Confirmed [18][19][20]). The Apache announcement list message and current Shodan and Censys counts were not checked.

Part 1: the flaw and the public record

What AJP is and why it was trusted

AJP, the Apache JServ Protocol version 1.3, is a binary protocol a front-end web server uses to forward requests to Tomcat. The proxy terminates the client connection and passes Tomcat the request along with facts it has established, such as the client address or an authenticated user (Confirmed [3][16]). Because those facts are supposed to come from the proxy, Tomcat treats AJP connections as having higher trust than a similar HTTP connection (Confirmed [1]).

That trust is safe only if nobody else can reach the connector, and before the fix nothing in the default configuration ensured that. Tomcat shipped with an AJP connector enabled by default that listened on all configured IP addresses, and its security guide expected administrators to disable it if they did not need it (Confirmed [1][2]). Apache's advisory lists the risks already known before Ghostcat: direct AJP access could bypass checks based on the client IP and could bypass authentication where Tomcat trusted proxy-supplied authentication data (Confirmed [3]).

What Ghostcat added

The January 2020 report identified a mechanism that allowed two more things (Confirmed [1]):

- **Returning arbitrary files from anywhere in the web application.** This includes `WEB-INF` and `META-INF`, the folders the servlet specification keeps private, and anything reachable through `ServletContext.getResourceAsStream()`. Configuration files, deployment descriptors and source files in those folders often carry database passwords and keys (Inferred).
- **Processing any file in the web application as a JSP.** If the application lets users upload files and stores them inside the web application, or an attacker can control a file's content another way, this turns into remote code execution (Confirmed [1]). Chaitin made the same point: an uploaded file of any type, even an image or text file, that contains JSP code can be included and run (Confirmed [18]).

The mechanism sits in how Tomcat's AJP processor handled request attributes. Before commit `64fa5b99` of 21 January 2020, `AjpProcessor.prepareRequest` set any AJP request attribute it did not recognise on the request without checking it (Confirmed [12]). The pinned public probe the lab used names the file Tomcat should return through three servlet include attributes, `javax.servlet.include.request_uri`, `javax.servlet.include.path_info` and `javax.servlet.include.servlet_path` (Confirmed [58]; Demonstrated [66]). The Apache advisory itself does not name these attributes; the mechanism here comes from the probe's source and the fix commit (Confirmed [1][12]).

What the fix changed

The 9.0.31, 8.5.51 and 7.0.100 changelogs carry the same AJP hardening (Confirmed [4][5][6]):

- The AJP/1.3 connector is disabled by default: it is commented out in `server.xml`.
- Its default bind address changes to the loopback address.
- `requiredSecret` is renamed `secret`, and a new `secretRequired` attribute defaults to `true`, so the connector will not start without a non-empty secret.
- A new `allowedRequestAttributesPattern` attribute lets an administrator allow named extra attributes; requests carrying any other unrecognised attribute are refused.
- The 9.0.31 changelog also adds guidance on securing AJP (Confirmed [4]).

The current Tomcat 9.0 connector reference keeps those defaults: the connector listens on loopback unless told otherwise, `secretRequired` defaults to `true` and should be `false` only on a trusted network, and requests whose arbitrary attributes do not match `allowedRequestAttributesPattern` (default null) are rejected with a 403 (Confirmed [7]). Tomcat's security guide adds that AJP is clear text, so the secret is visible to anyone who can observe the traffic, and that unused connectors should be removed (Confirmed [8]).

On the 9.0.x branch Apache lists five fix commits: `0e8a50f0` ("Change the default bind address for AJP to the loopback address") and `9ac90532` ("Rename requiredSecret to secret and add secretRequired"), both of 21 January 2020; `64fa5b99`, the attribute check, the same day; `7a1406a3` ("Tweak AJP improvements") of 4 February; and `49ad3f95` ("Refactor secret check") of 5 February (Confirmed [1][12][13]). The attribute allow-list was first named `allowedArbitraryRequestAttributes` and was renamed before release (Confirmed [12][4]). The 8.5.x fix is commits `69c56080`, `b962835f`, `5a5494f0`, `9be57601`, `64159aa1` and `03c43612`; the 7.0.x fix is `0d633e72`, `40d5d93b`, `b99fba5b` and `f7180baf` (Confirmed [2][3]).

Apache's framing of the fix is narrow and worth keeping: mitigation is only required if an AJP port is accessible to untrusted users, and upgrading to 9.0.31 or later blocks the file-return and JSP vector as defence in depth (Confirmed [1]). It also warns that upgrading will likely need small configuration changes, because the default AJP configuration was hardened (Confirmed [1]).

Affected and fixed versions

Branch	Affected	Fixed	Fix release date	Support today
9.0.x	9.0.0.M1 to 9.0.30	9.0.31	11 February 2020	Supported [1]
8.5.x	8.5.0 to 8.5.50	8.5.51	11 February 2020	End of life 31 March 2024 [2][15]
7.0.x	7.0.0 to 7.0.99	7.0.100	14 February 2020	End of life 31 March 2021 [3][15]
6.0.x	All, per Chaitin and CNVD	None upstream (RHEL 6 tomcat6 fixed, RHSA-2020:0912 [27])	Never fixed upstream	End of life 31 December 2016 [15][18][19]

NVD's CPE ranges match the Apache rows: 7.0.0 to before 7.0.100, 8.5.0 to before 8.5.51 and 9.0.0 to before 9.0.31 (Confirmed [21]). The CNA's affected-version text in the CVE record has a typo, "9.0.0.30" for 9.0.30 (Confirmed [22]). The embedded jar is covered separately: GHSA-c9hw-wf7x-jp9j lists `org.apache.tomcat.embed:tomcat-embed-core` below 9.0.31, 8.5.51 and 7.0.100, which is the copy that ships inside Spring Boot and similar fat jars (Confirmed [26] for the package; Reported [36] for Spring Boot).

Scores and their disagreements

Source	Rating
NVD	CVSS 3.1 9.8 Critical (`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`); CVSS 2.0 7.5 (`AV:N/AC:L/Au:N/C:P/I:P/A:P`) [21]
CVE record, CISA-ADP container	CVSS 3.1 9.8, the same vector; the CNA container has no CVSS score [22]
Apache	Important on its pages for Tomcat 9 and 8, High on its Tomcat 7 page [1][2][3]
CNVD	High; CVSS 2 10.0 (`AV:N/AC:L/Au:N/C:C/I:C/A:C`) [19][20]
Red Hat	Important [27]
Ubuntu	Priority Low; Ubuntu notes its packages disable the AJP connector by default [29]
GitHub advisory	Critical [26]
CISA SSVC	Exploitation active, Automatable yes, Technical Impact total [22]
FIRST EPSS	0.9927, percentile 0.99937, on 3 November 2026 [25]

The spread is a configuration story, not a disagreement about the code. Ubuntu rates it Low and notes that its packaged Tomcat disables AJP by default, and Debian notes that its default configuration has disabled AJP since 2008 (Confirmed [28][29]). Apache's stock tarball opened it on every address (Confirmed [1]). The same flaw is a 9.8 on one host and nothing at all on another (Inferred).

Weakness labels

No record opened assigns the same weakness, and NVD assigns none (Confirmed [21][22][23][26][27]):

Record	Weakness
NVD	`NVD-CWE-Other` [21]
CVE record, CISA ADP container	`CWE-noinfo` [22]
CNA problem type	Free text: "AJP Request Injection leading to possible Remote Code Execution" [22]
GitHub advisory GHSA-c9hw-wf7x-jp9j	CWE-269 Improper Privilege Management [26]
Red Hat	CWE-285 Improper Authorization [27]
CISA KEV	`cwes` field empty; the entry is named "Apache Tomcat Improper Privilege Management Vulnerability" [23]

The KEV name matches the title of CWE-269, but KEV's own weakness field is empty (Confirmed [23][63]). This study lists each label by its source and binds none of them as the CVE's weakness (Inferred). Part 6 gives this study's own reading.

Timeline

Date	Event	Source
2 December 2019	CVE-2020-1938 reserved by the Apache CNA	[22]
3 January 2020	Chaitin Tech reports the flaw to the Apache Tomcat Security Team	[1][18]
6 January 2020	CNVD receives the report from Beijing Chaitin Tech (CNVD-2020-10487)	[19][20]
21 January 2020	Commits `0e8a50f0`, `9ac90532` and `64fa5b99` on 9.0.x: loopback bind, `secret` and `secretRequired`, the attribute check	[12][13]
4 and 5 February 2020	Commits `7a1406a3` and `49ad3f95` complete the 9.0.x fix	[13]
11 February 2020	Tomcat 9.0.31 and 8.5.51 released	[1][2][4][5]
14 February 2020	Tomcat 7.0.100 released	[3][6]
20 February 2020	CNVD notice CNTA-2020-0004 and Chaitin's Ghostcat notice; CNVD-2020-10487 public; Exploit-DB EDB-48143 published; Red Hat's public date	[18][19][20][27][38]
21 February 2020	Tenable post on Ghostcat; DShield records 85,318 port 8009 events, against a February norm of 1,000 to 7,000 a day	[33][46]
22 February 2020	DIVD CSIRT reports 773 vulnerable Dutch IP addresses	[37]
24 February 2020	Apache makes the issue public; NVD publishes CVE-2020-1938	[1][21]
25 February 2020	Emerging Threats Open rule `2029533` for Ghostcat attempts created	[55]
27 to 28 February 2020	AppCheck and The Hacker News relay exposure estimates of about 170,000 AJP hosts (ONYPHE) up to about 1 million (Shodan, BinaryEdge); FortiGuard ships an IPS signature	[35][40][41]
29 February to 1 March 2020	Bad Packets reports mass scanning, including hundreds of unique scans checking for `/WEB-INF/web.xml`	[43][44][45]
2 March 2020	Apache announces the end of 7.0.x support for 31 March 2021	[15]
7 and 12 March 2020	Further DShield port 8009 spikes of 43,303 and 53,954 events	[46]
10 March 2020	Trend Micro "Busting Ghostcat" analysis	[36]
17 and 23 March 2020	Red Hat ships fixed RHEL 7 (RHSA-2020:0855) and RHEL 6 (RHSA-2020:0912) Tomcat packages	[27]
24 March 2020	Tenable Nessus plugin 134862 published	[34]
15 June 2020	GitHub advisory GHSA-c9hw-wf7x-jp9j for `tomcat-embed-core` published	[26]
14 July and 20 October 2020	Oracle Critical Patch Updates list the CVE in bundled Tomcat across several products	[30][31]
13 to 16 November 2020	A Metasploit module, "Apache Tomcat AJP File Read", appears as EDB-49039 and lands in the Metasploit framework	[39]
31 March 2021	Tomcat 7.0.x support ends	[15]

Date	Event	Source
3 March 2022	CISA adds CVE-2020-1938 to KEV in a batch of 95 entries, due 17 March 2022	[23][24]
13 December 2022	Apache announces the end of 8.5.x support for 31 March 2024	[15]
7 June 2023	Emerging Threats rule `2046149` for a `web.xml` licence header in an AJP reply created	[55]
31 March 2024	Tomcat 8.5.x support ends	[15]
6 February 2025	CISA SSVC timestamp: exploitation active, automatable, total impact	[22]
June 2026	A honeypot report logs 312 Ghostcat payloads from 65 source IPs	[52]
September 2026	Recorded Future lists CVE-2020-1938 among vulnerabilities exploited or weaponized that month	[49]
October 2026	DShield still records about 950 to 6,200 port 8009 events a day; a ZoomEye query counts 1,240,557 ajp13 fingerprints	[47][53]
3 November 2026	KEV catalog 2026.11.03 still lists the CVE; EPSS 0.9927; the TeamStarWolf lab run	[23][25][65]

Two disclosure dates circulate. CNVD, Chaitin and Red Hat put the public date at 20 February 2020; Apache and NVD use 24 February (Confirmed [1][19][21][27]). 9.0.31 and 8.5.51 predate the 20 February notices by nine days and 7.0.100 by six (Confirmed [1][3]; Inferred for the arithmetic).

Part 2: who exploited it, and how widely

Code and scanning came fast

Public proof-of-concept code existed from the day of the CNVD notice: Exploit-DB lists EDB-48143, "Apache Tomcat - AJP 'Ghostcat File Read/Inclusion", dated 20 February 2020 (Demonstrated [38]). Tenable's post of 21 February linked several proof-of-concept repositories already on GitHub, and SecurityWeek reported that different researchers released several more and that Chaitin released online and offline detection tools (Confirmed [33]; Reported [42]). A Metasploit module followed in November 2020 (Confirmed [39]).

Scanning followed within about a week. BleepingComputer and Security Affairs relayed Bad Packets' report that mass scanning had begun over the weekend of 29 February, and SecurityWeek relayed its 1 March report of hundreds of unique scans from hosts in China, excluding known researchers, that checked for `/WEB-INF/web.xml` (Reported [43][44][45]). The Bad Packets posts themselves were not opened. SANS ISC's DShield sensors give a sensor-side view: port 8009 events ran mostly between 1,000 and 7,000 a day in February 2020, jumped to 85,318 on 21 February, the day after the CNVD notice and the first public proof of concept, and spiked again to 43,303 on 7 March and 53,954 on 12 March (Confirmed [46]). DShield counts traffic to the port, not Ghostcat requests, so tying the spikes to Ghostcat is Inferred.

How many hosts were exposed

Every exposure count in the record is a search-engine or national estimate, and they measure different things:

Count	What it measures	Source	Grade
About 555,000 Tomcat AJP IPs in China; 43,197 affected (about 7.8 percent)	CNVD's own count, February 2020	[19]	Confirmed
773 vulnerable Dutch IP addresses	DIVD CSIRT scan, 22 February 2020	[37]	Reported
More than 170,000 devices exposing an AJP connector	ONYPHE, relayed by AppCheck, The Hacker News and SecurityWeek, late February 2020	[40][41][45]	Reported
About 1 million	Shodan and BinaryEdge, relayed by AppCheck	[40]	Reported
More than 890,000 to 900,000 Tomcat servers	Shodan, relayed by BleepingComputer and Security Affairs; Tomcat in general, not AJP or version-filtered	[43][44]	Reported
2,107,044 services on port 8009; 1,240,557 with the ajp13 fingerprint	ZoomEye query of 25 October 2026, relayed by a DEV Community post that cautions the fingerprint is not a version or configuration check	[53]	Reported

No count in the record says how many of these hosts were both reachable and unpatched, and current Shodan and Censys figures were not checked (Inferred).

Who used it

The exploitation record is real but anonymous:

- **CISA catalogued it.** KEV added CVE-2020-1938 on 3 March 2022 in a batch of 95 entries that CISA described as added "based on evidence of active exploitation" (Confirmed [23][24]). The alert does not list CVEs individually; the feed is the per-CVE record (Confirmed [24]).
- **CISA's SSVC entry says active and automatable.** The CISA ADP container, timestamped 6 February 2025, rates exploitation active, automatable yes and technical impact total (Confirmed [22]).
- **No named actor.** No opened primary source names a threat actor, campaign or malware family exploiting CVE-2020-1938; KEV marks ransomware use as Unknown; FortiGuard's threat signal names no actor; and Palo Alto Networks Unit 42's network attack trend reports for November 2020 to January 2021 and August to October 2021 do not mention it (Confirmed [23][35]; Inferred [48] for the absence). This is an absence across the sources searched, not proof of absence (Inferred).
- **A 2026 report, without its underlying evidence.** Recorded Future's "September 2026 CVE Landscape" lists CVE-2020-1938 among vulnerabilities actively exploited or operationally weaponized that month, and says a suspected Chinese-speaking actor using a SecFlow-based, LLM-assisted environment tested or staged Ghostcat workflows against Asian targets, not every attempt producing confirmed access (Reported [49]). The post names no actor and links no underlying report, so this study carries it as a single-source claim.
- **Honeypots and pentesters still see it.** OffSeq's Mirage honeypot report logged 312 Ghostcat exploit payloads from 65 source IPs, third by volume, while stressing that most CVE-tagged honeypot events are scanning or brute force; its post date (21 June 2026) conflicts with its stated data window in June and July (Reported [52]). Pentest-Tools.com ranks Ghostcat third in its list of the most exploited vulnerabilities of 2022, based on what its offensive staff most often proved to be a real risk, without stating method or numbers (Reported [50]). Edgescan's 2024 report lists the CVE among the PCI failures with the highest

EPSS in its customer estate (Confirmed [51]).

- **Proof-of-concept interest has not stopped.** CIRCL's Vulnerability-Lookup records 61 sightings of the CVE as of 4 November 2026, with published proof-of-concept sightings in every year from 2020 to 2026, 12 of them in 2026 (Confirmed [54]). Reading that as sustained interest is Inferred.

Trend Micro's March 2020 analysis gives the most grounded threat model: Ghostcat is not code execution by default, code execution needs an upload feature that stores files in the document root plus a reachable AJP port, most public proofs of concept pre-placed a web-shell file in `webapps/ROOT` to demonstrate it, and lateral movement inside a network is the realistic abuse (Confirmed [36]). Port 8009 is rarely meant to face the internet, so the host an attacker reaches from inside a network matters as much as the internet-facing count (Inferred [36]).

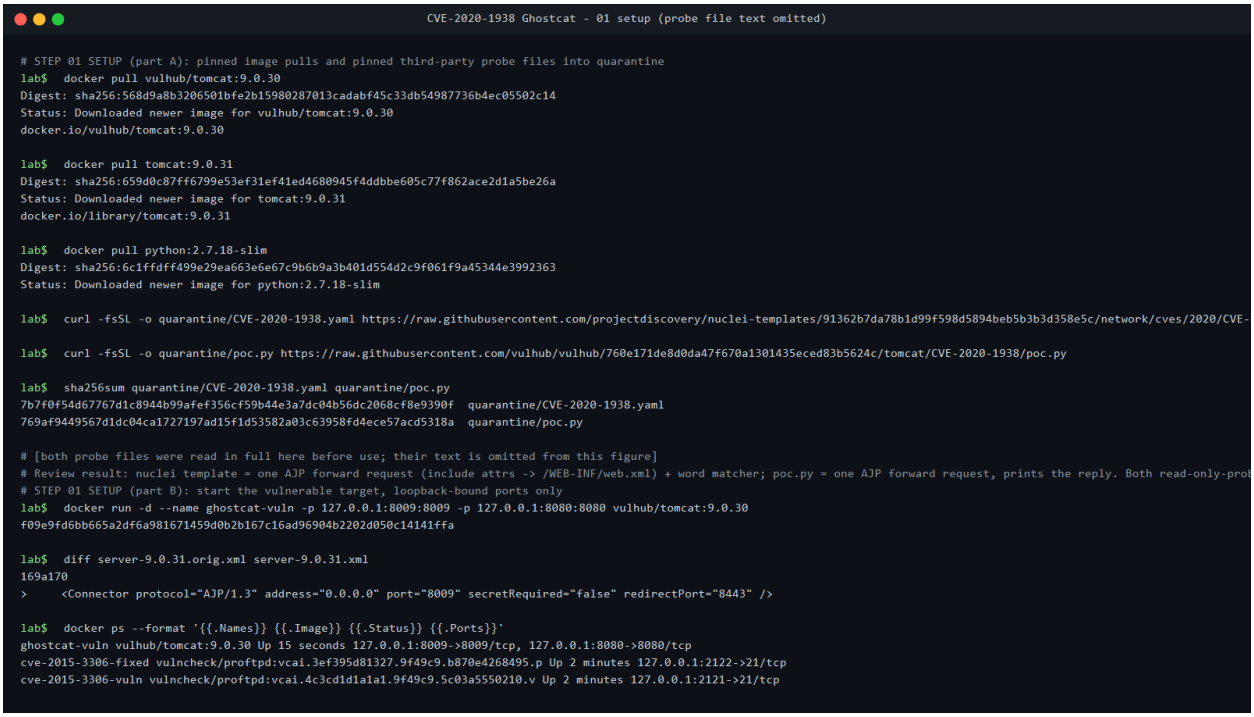
Part 3: what the lab showed

The lab

The vulnerable target was `vulhub/tomcat:9.0.30` and the control was the official `tomcat:9.0.31`, with `python:2.7.18-slim` as the probe runtime, all pulled by digest (Demonstrated [66]). The stock `tomcat:9.0.30` image has an empty `webapps` folder, so the lab used the vulhub image, which is built from `tomcat:9.0.30-jdk8-openjdk` with the default web applications restored (Demonstrated [65]; Reported [59]). Both image tags are active on Docker Hub (Confirmed [60]). Each container published ports 8009 and 8080 on `127.0.0.1` only (Demonstrated [66][67]).

Two third-party probes were used, each fetched at a pinned commit into a quarantine folder, printed in full, hashed and reviewed as read-only before use (Demonstrated [66]): the ProjectDiscovery nuclei template `CVE-2020-1938.yaml` at commit `91362b7d` and the vulhub `poc.py` at commit `760e171d`, both from MIT-licensed repositories (Confirmed [57][58]). Fetched again on 4 November 2026 at the same commits, both files hashed to the lab's values, `7b7f0f54...390f` and `769af944...318a` (Confirmed [57][58]). Each probe sends one AJP forward request that sets the three include attributes to name `WEB-INF/web.xml`, then reports the reply; neither has a write, upload or execute path (Confirmed [57][58]).

The control's configuration was the stock 9.0.31 `server.xml` plus one added line: an AJP connector on `0.0.0.0:8009` with `secretRequired="false"` (Demonstrated [66][69]). That deliberately recreates the old exposure on the fixed code, so the remaining differences are the Tomcat code and the image builds, vulhub's 9.0.30 image against the official 9.0.31 (Demonstrated [65][66]).



Capture `01-setup.txt`, 3 November 2026: pinned images and probes, loopback-only ports, and the one-line control change. The full text of both probe files, which the capture prints, is omitted from this figure, which is re-rendered from the capture's setup, hash, review, run, diff and container lines.

The vulnerable build, step by step

1. **Version.** `bin/version.sh` printed `Server number: 9.0.30.0`, and the HTTP error page footer read `Apache Tomcat/9.0.30` (Demonstrated [67][68]).
2. **Listener.** Inside the container, port `0x1F49` (8009) listened on the all-zero address, and the log showed `ProtocolHandler ["ajp-nio-8009"]` initialising and starting (Demonstrated [67][68]).
3. **The probe.** The nuclei template reported a critical CVE-2020-1938 match on `127.0.0.1:8009`; its debug hexdump showed an AJP reply with status 200 followed by the XML declaration and licence text of `web.xml` (Demonstrated [67]). A plain `grep` for the licence sentence in that output printed nothing, because the sentence is split across hexdump rows; the hexdump lines carry the evidence (Demonstrated [67]).
4. **The second probe.** Python 2.7 refused to run `poc.py` as a file, because of a non-ASCII comment on line 2 with no coding declaration (PEP 263). The unchanged bytes, hash checked again, were loaded through `exec()` instead (Demonstrated [67]). The probe returned `WEB-INF/web.xml`: the XML declaration, the Apache licence header and `<display-name>Welcome to Tomcat</display-name>` (Demonstrated [67]).
5. **The contrast.** On the same target, an HTTP request for `/WEB-INF/web.xml` returned `404` (Demonstrated [67]). AJP handed out a file that HTTP refuses.

The fixed build, same probes

The control reported `Server number: 9.0.31.0`, logged `ProtocolHandler ["ajp-nio-0.0.0.0-8009"]` starting, and held the default web applications, including `ROOT/WEB-INF/web.xml` (Demonstrated [67][69]). So the file was there and the connector was open.

- The nuclei template found no match; the AJP reply carried status 403 and an `HTTP Status 403` page (Demonstrated [67]).
- `poc.py` received an `HTTP Status 403 – Forbidden` page footed `Apache Tomcat/9.0.31` (Demonstrated [67]).
- Counting the licence sentence in the two saved outputs gave `t5-vuln.txt:1` and `t9-fixed.txt:0` (Demonstrated [67]).

The 9.0.31 changelog says requests with unrecognised attributes are blocked with a 403, which matches what the lab saw (Confirmed [4]). Pinning the 403 to the attribute check, rather than to another part of the fix, is Inferred: the secret could not be the cause, because the control had `secretRequired="false"` (Demonstrated [69]).

The test-step screenshot is not reproduced here; it prints the probe invocations. The capture lines quoted above are the observable differences.

The exposure checks



Capture `03-exposure.txt`, 3 November 2026: version, listener, connector line, jar and package checks, service fingerprint and banner, all read-only.

- Line 116 of the target's `server.xml` was the stock `<Connector port="8009" protocol="AJP/1.3" redirectPort="8443" />`, with no `address`, `secret` or `secretRequired` (Demonstrated [68]). Upstream `conf/server.xml` at tag 9.0.30 carries the same active connector (Confirmed [14]).
- On the lab host, `ss -ltn` showed only `127.0.0.1:8009`, the Docker loopback publish, while inside the container the listener was on all addresses (Demonstrated [68]). A host-side check alone would have understated the container's own bind.

- `nmap -sV -Pn -p 8009` reported `8009/tcp open ajp13 Apache Jserv (Protocol v1.3)` (Nmap 7.99) (Demonstrated [68]).
- `dpkg -l | grep tomcat` found nothing on the tarball-installed image, and the jar search found `catalina.jar` and `tomcat-coyote.jar` but no `tomcat-embed-core` (Demonstrated [68]). A package query alone misses a tarball install (Inferred [68]).

The mitigation check

```
CVE-2020-1938 Ghostcat - 04 mitigation verification

# STEP 04 MITIGATION VERIFICATION (read-only checks)
# M1 vendor fix: the patched build is 9.0.31 and it refuses the include-attribute AJP read with 403 (T8/T9 above); c
lab$  docker exec ghostcat-fixed sh -c '/usr/local/tomcat/bin/version.sh 2>/dev/null | grep -E "Server version|Serve
Server version: Apache Tomcat/9.0.31
Server number:  9.0.31.0

# M2 hardened default config in stock 9.0.31: the AJP connector ships commented out, bound to ::1, with a secret pla
lab$  sed -n '115,122p' server-9.0.31.orig.xml
    <!-- Define an AJP 1.3 Connector on port 8009 -->
    <!--
    <Connector protocol="AJP/1.3"
               address="::1"
               port="8009"
               redirectPort="8443" />
    -->


# M2b the only change made for the control was this one deliberately exposed connector line
lab$  diff server-9.0.31.orig.xml server-9.0.31.xml
169a170
>     <Connector protocol="AJP/1.3" address="0.0.0.0" port="8009" secretRequired="false" redirectPort="8443" />

# M3 even on the fixed build, HTTP still refuses WEB-INF (expect 404)
lab$  curl -s -o /dev/null -w '%{http_code}\n' http://127.0.0.1:8080/WEB-INF/web.xml
404

# M4 the AJP read leaves no trace in the HTTP access log (control's localhost_access_log lists only HTTP requests)
lab$  docker exec ghostcat-fixed sh -c 'cat /usr/local/tomcat/logs/localhost_access_log.*.txt 2>/dev/null || echo "r
127.0.0.1 - - [04/Nov/2026:04:10:18 +0000] "GET /examples/xxxxx.jsp HTTP/1.1" 403 618
127.0.0.1 - - [04/Nov/2026:04:10:18 +0000] "GET /asdf HTTP/1.1" 403 618

# CORRECTION to the M4 comment and to the plan's Inferred detection note: the AJP probe requests (nuclei /examples/x
```

Capture `04-mitigation.txt`, 3 November 2026 (container clock 4 November UTC). Two comment lines in the capture do not match its output: the M2 comment mentions a secret placeholder that the printed lines do not show, and the M4 comment expects no log trace, which the log lines below it contradict, as the capture's correction line, cut off at the image's right edge, records.

- Stock 9.0.31 ships the AJP connector commented out and bound to `address="::1"`, and upstream `conf/server.xml` at tag 9.0.31 matches (Demonstrated [69]; Confirmed [14]).
- HTTP still returned `404` for `/WEB-INF/web.xml` on the fixed build, so a 404 on HTTP says nothing about AJP either way (Demonstrated [69]).

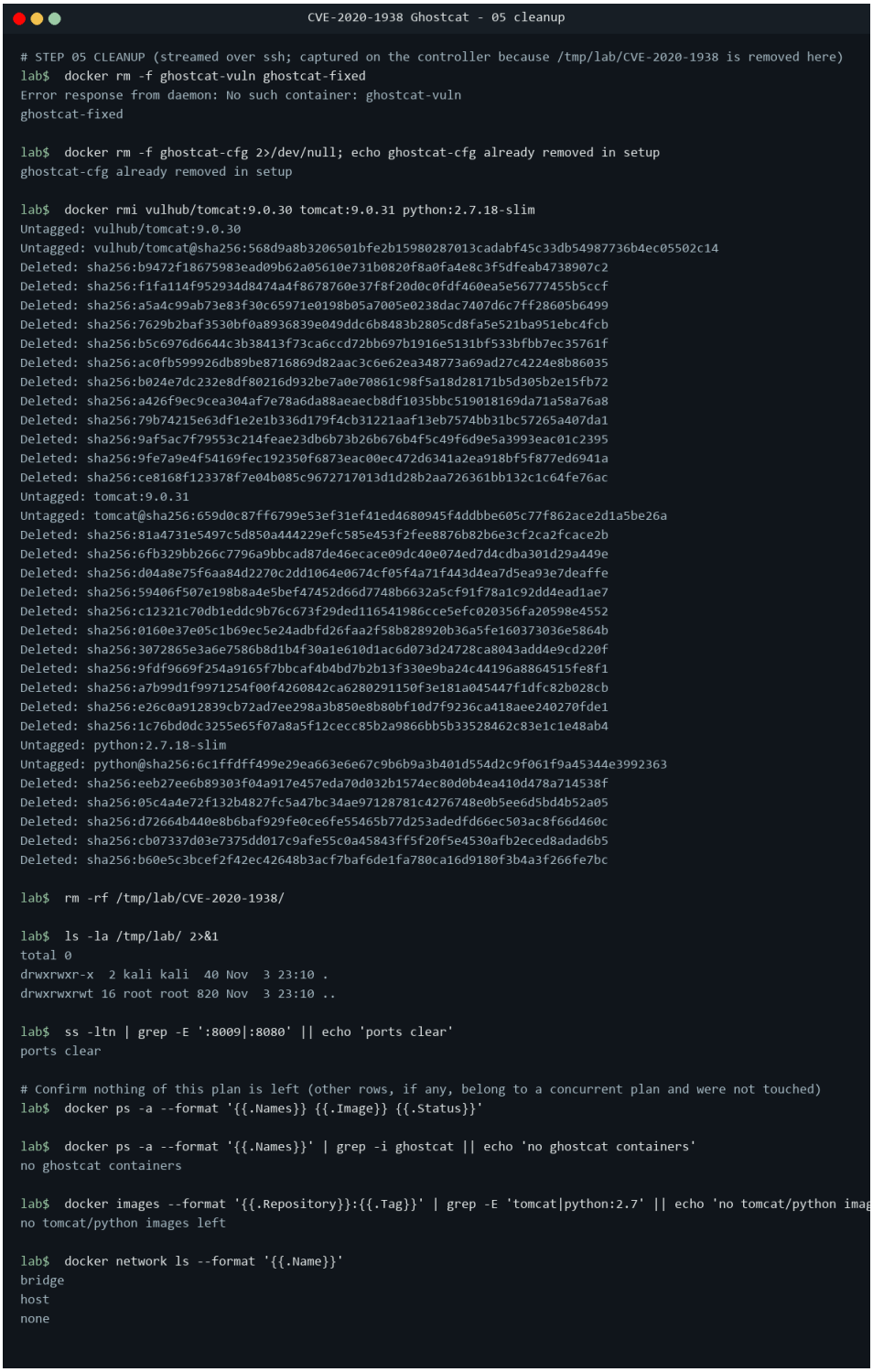
The access-log finding

The lab plan expected AJP requests to leave no trace in Tomcat's access log. They do. On the 9.0.31 control, `localhost_access_log` recorded both probe requests at `04/Nov/2026:04:10:18 +0000`, as `"GET /examples/xxxxx.jsp HTTP/1.1" 403 618` and `"GET /asdf HTTP/1.1" 403 618` (Demonstrated [69]). The capture's correction line records the finding against the plan (Demonstrated [69]).

The logged request line is the AJP forward URI the probe chose as a decoy, not the file it asked for through the include attributes. The access log never names `WEB-INF/web.xml` (Demonstrated [69]). That follows from the log format: in both 9.0.30 and 9.0.31 the stock `AccessLogValve` sits on the Host with the pattern `%h %l %u %t "%r" %s %b`, and Tomcat defines `%r` as the first line of the request, its method and request URI (Confirmed [11][14]). Two limits apply:

- The vulnerable target's access log was not checked, because its container was removed before the log check. The same valve sits on the Host in upstream 9.0.30, so the same lines with status 200 are expected there, but that was not run (Inferred [14]).
- An AJP forward request carries its own `remote_addr` field, and `poc.py` fills it with the target host address, so `%h` on an AJP-borne line may be client-supplied rather than the real peer. In the lab both were `127.0.0.1`, so the lab cannot tell them apart (Inferred [58]).

Cleanup



Capture `05-cleanup.txt`, 3 November 2026.

The control container was removed (the vulnerable one was already gone), all three images were untagged and deleted, the lab folder was left empty, and the checks printed `ports clear`, `no ghostcat containers` and `no tomcat/python images left`, with only the default Docker networks remaining (Demonstrated [70]).

What the lab did not do

Only the file-read half of the advisory was exercised. The include-as-JSP path combined with an upload, which is the code-execution chain, and the evaluation mode of a third-party tool were recorded in the plan as destructive or weaponized and were not run (Demonstrated [65]). The lab ran one pair of builds on one branch, 9.0.30 against 9.0.31; it did not test 8.5 or 7.0, a distribution package, a vendor bundle, an embedded jar, or a connector with a secret set.

Part 4: find and fix it on real hosts

The checks below read state only. Each answers one question: which Tomcat is this, is its AJP connector on, and who can reach it.

Check 1: which Tomcat, and which version

```
"$CATALINA_HOME/bin/version.sh" | grep -E 'Server version|Server number'
find / \( -name 'tomcat-embed-core-*.jar' -o -name 'catalina.jar' -o -name 'tomcat-coyote.jar' \
) 2>/dev/null
dpkg -l | grep -i tomcat      # Debian and Ubuntu packages
rpm -qa | grep -i tomcat      # RHEL and derivatives
```

`version.sh` is the authority. Tomcat's security guide notes that the HTTP banner can be changed through `ServerInfo.properties` or hidden with `showServerInfo="false"`, while `bin/version.sh` or `bin/version.bat` still reports the real version (Confirmed [8]). The lab read `Server number: 9.0.30.0` this way and saw the same version in the HTTP footer (Demonstrated [68]). On the tarball image the package query found nothing, so run the file search as well (Demonstrated [68]). A host can carry several instances: `CATALINA_BASE` defaults to `CATALINA_HOME`, but each base has its own `conf/server.xml`, and each one needs checking (Confirmed [10]).

The `rpm` line and the combined `find` are this study's extension of the lab's commands (Inferred).

On Windows, Tomcat installs as a service named `Tomcat9` by default, with `tomcat9.exe` as the service binary and `tomcat9w.exe` as its configuration tool; `tomcat9 //PS//Tomcat9` prints the service configuration (Confirmed [9]). These standard commands, not taken from a Ghostcat source and not run in the lab, find the service, the listener and the version (Inferred):

```
Get-Service *tomcat*
sc.exe query Tomcat9
Get-NetTCPConnection -LocalPort 8009 -State Listen
& "$env:CATALINA_HOME\bin\version.bat"
```

Check 2: is the AJP connector on, and where does it bind

```
grep -n -A4 'AJP/1.3' "$CATALINA_BASE/conf/server.xml"
```

Read the result with the version from Check 1. The rows are this study's reading of the advisory, the connector reference and the lab (Confirmed [1][4][7]; Demonstrated [68][69]; Inferred for the readings):

Version	Connector state	Reading
Below 9.0.31, 8.5.51 or 7.0.100, or any 6.x	Uncommented AJP connector with no `address`	Exposed on all addresses: fix now

Version	Connector state	Reading
Below the fix line	Connector commented out or removed	Not reachable over AJP; upgrade on the normal schedule
Below the fix line	`address` set to loopback or a private address, `requiredSecret` set	Narrowed; still upgrade
At or above the fix line	Stock commented-out connector, or one with `address` and `secret`	The hardened default
At or above the fix line	`secretRequired="false"` on a reachable address	The lab's control: the code fix still refused the read, but the connector is open; restore the secret

For distribution packages, read the fix line as the distribution advisory's fixed package, not the upstream version number (see the distribution table below).

Check 3: who can reach port 8009

```
ss -ltnp | grep ':8009'
nmap -sV -Pn -p 8009 <your-host>
```

Run the port check on the host and, for containers, inside the container too: the lab host showed a loopback publish while the container listened on every address (Demonstrated [68]). The `nmap` fingerprint `ajp13 Apache Jserv (Protocol v1.3)` identifies the protocol, not the version (Demonstrated [68] for the fingerprint; Inferred, and cautioned by [53], that it carries no version). Nmap's `ajp-headers` script queries an AJP server for its response headers (Confirmed [56]). Scan from where an attacker would stand: outside the network for internet exposure, and from ordinary internal segments, since Trend Micro rates lateral movement as the realistic abuse (Confirmed [36]; Inferred for the advice). Only scan hosts you are authorized to test.

Scanner content exists for confirmation. Tenable's Nessus plugin 134862, "Apache Tomcat AJP Connector Request Injection (Ghostcat)", is a remote check published 24 March 2020 (Confirmed [34]). The nuclei template the lab used is a single read-only request with a word matcher (Confirmed [57]).

Distribution packages: compare against the advisory, not the upstream number

Distributions backport fixes, so a fixed package can report a version below the upstream fix line (Confirmed [27][28]):

Platform	Fixed package and advisory
Debian 10 (buster)	`tomcat9` 9.0.31-1~deb10u1, DSA-4680-1 [28]
Debian 9 (stretch)	`tomcat8` 8.5.54-0+deb9u1, DSA-4673-1 [28]
Debian 8 (jessie)	`tomcat8` 8.0.14-1+deb8u17, DLA-2209-1; `tomcat7` 7.0.56-3+really7.0.100-1, DLA-2133-1 [28]
Ubuntu	Priority Low; `tomcat9` not affected from 20.04; 16.04 and 18.04 packages marked ignored at end of standard support; packages disable AJP by default [29]
RHEL 6	`tomcat6-6.0.24-114.el6_10`, RHSA-2020:0912 (23 March 2020) [27]

Platform	Fixed package and advisory
RHEL 7	`tomcat-7.0.76-11.el7_7`, RHSA-2020:0855 (17 March 2020) [27]
RHEL 8	`pki-core` and `pki-deps`, RHSA-2020:4847 [27]
Red Hat middleware	JBoss Web Server 3, RHSA-2020:0861; JBoss Web Server 5.3 `jws5-tomcat-9.0.30-3.redhat_4`, RHSA-2020:1520; JBoss EAP 6.4 `jbossweb`, RHSA-2020:1478 and 1479; Fuse 7.9, RHSA-2021:3140; Spring Boot 2.1.13 runtime, RHSA-2020:2367; OpenStack 13 OpenDaylight marked Will not fix [27]

A fixed RHEL 7 package reports 7.0.76 and a fixed Debian jessie `tomcat8` reports 8.0.14, both below the upstream fix lines, and Red Hat's fixed JBoss Web Server build carries 9.0.30 in its name. A scanner that compares only upstream version numbers will flag these fixed builds as vulnerable, while an inventory that only queries packages misses a tarball install beside them (Inferred [27][28]; Demonstrated [68]). Debian also notes that its default configuration has disabled AJP since 2008 (Confirmed [28]).

Vendor bundles and embedded copies

Tomcat ships inside other products, and each needs its own vendor's fix. Oracle's July 2020 Critical Patch Update lists CVE-2020-1938 in the bundled Tomcat of Communications Element Manager, Communications Instant Messaging Server, Health Sciences Empirica Inspections and Empirica Signal, Hospitality Guest Access, MySQL Enterprise Monitor and Siebel UI Framework, and the October 2020 update adds Agile PLM (Confirmed [30][31]). NVD's CPE data also lists Apache Geode 1.12.0, BlackBerry Good Control and Workspaces Server, and NetApp Data Availability Services and OnCommand System Manager 3.0.0 to 3.1.3; those vendors' own advisories were not opened (Confirmed [21]).

A bundled vulnerable version is not the same as an exposed connector. Oxygen XML's advisory says Web Author 22.0.0 and older and Content Fusion 1.2 and older bundle an affected Tomcat but do not enable the AJP connector, so they are not impacted (Confirmed [32]). Embedded applications need a dependency bump: GHSA-c9hw-wf7x-jp9j covers `tomcat-embed-core` below the fix lines (Confirmed [26]). Whether a given Spring Boot release enables AJP by default was not checked.

Apply the fix

1. **Upgrade.** Move to a supported Tomcat at or above 9.0.31; current 9.0.x documentation describes the hardened defaults (Confirmed [1][7]). 7.0 and 8.5 are end of life, and Apache's 8.5 page recommends 9.0 or later (Confirmed [2][15]). On a distribution, install the vendor's fixed package; for embedded copies, raise `tomcat-embed-core` (Confirmed [26][27][28]).
2. **Expect configuration work if you use AJP.** After the upgrade the connector stays off until you enable it, binds to loopback unless given an `address`, and will not start without a `secret` (Confirmed [4][7]). Apache warns that upgrades will likely need small configuration changes (Confirmed [1]).
3. **Set the secret on both sides.** Apache httpd's `mod_proxy_ajp` takes a `secret=` parameter on `ProxyPass` and `BalancerMember` from httpd 2.4.42, which the httpd documentation says is needed because Tomcat requires the secret by default from 8.5.51 and 9.0.31 (Confirmed [16]). With `mod_jk`, `worker.<name>.secret` must match the connector's `secret`; releases before February 2020 called the Tomcat attribute `requiredSecret` (Confirmed [17]).

4. **Verify.** Re-run Check 1 to Check 3. The lab's control shows what a fixed build answers to the probe, a 403, even with the connector open (Demonstrated [67]).

A connector that a proxy needs, written with the documented attributes, looks like this (attributes Confirmed [7]; the layout is this study's example):

```
<Connector protocol="AJP/1.3"
           address="127.0.0.1"
           port="8009"
           secret="a-long-random-value-shared-with-the-proxy"
           redirectPort="8443" />
```

If you cannot upgrade yet

- **If nothing uses AJP,** comment out or remove the connector in `conf/server.xml` and restart; the security guide says unused connectors should be removed (Confirmed [8]; Reported [33]).
- **If a proxy uses it,** bind it to loopback or a private address and set `requiredSecret` on the connector, the pre-fix name, with the matching secret on the proxy (Confirmed [17][18]).
- **Firewall port 8009** so only the proxy can reach it; Ubuntu and Chaitin both give this advice (Confirmed [18][29]).
- **Upstream Tomcat 6 has no fix.** Its support ended in 2016 and Tenable advised moving off it (Confirmed [15]; Reported [33]). Red Hat fixed its RHEL 6 tomcat6 package in RHSA-2020:0912 (Confirmed [27]); for any other Tomcat 6, the connector changes above are the only controls.

These are bridges. Apache's position is that mitigation is required only where untrusted users can reach AJP, and that the upgrade blocks the file-return and JSP vector even where they can (Confirmed [1]).

Detection

- **Network signatures.** Emerging Threats Open rule `2029533`, "GhostCat LFI Attempt Inbound (CVE-2020-1938)", matches the AJP magic bytes `0x1234` on TCP 8009 together with the three `javax.servlet.include` attribute names (created 25 February 2020, updated 14 March 2024); rule `2046149` flags a `web.xml` licence header in the reply, which is what a successful read returns (Confirmed [55]). FortiGuard ships IPS signature `Apache.Tomcat.AJP.Local.File.Inclusion` (Confirmed [35]), and Trend Micro names DDI rule 4354, Deep Security rule 1010184 and TippingPoint filter 37236 (Reported [36]).
- **Tomcat's access log.** AJP requests land in the Host `AccessLogValve` log (Demonstrated [69]). Because `%r` records the forward URI, not the include path, hunt for request lines that your proxy would never send, such as made-up paths or JSP names that do not exist in the application, arriving on hosts where AJP should carry only proxy traffic (Demonstrated [69]; Inferred for the hunting rule). Do not trust `%h` on those lines as the attacker's address (Inferred [58]).
- **Connections to 8009 from anything but the proxy.** On a host where only the proxy should speak AJP, any other source is worth an alert. The lab plan's detection ideas, a Sigma network-connection rule for port 8009 from non-proxy sources and a rule over Suricata output, were not tested (Inferred [65]).

If 8009 was reachable by untrusted sources

Assume the files in `WEB-INF` and `META-INF` were read. Rotate the database passwords, API keys and signing secrets kept in those folders, and if the application accepts uploads into its own folders, look for files that do not belong there (Inferred [1][65]).

Part 5: the vulnerability-management view

Ghostcat is six years old and still in the KEV catalog, which makes it a useful test of a program's inventory rather than its patch speed.

- **The exposure was an ancillary default.** The flaw was reachable only through a second listener that the stock tarball opened on every address and that most deployments never used (Confirmed [1]). A check that only requests files over the HTTP port sees nothing: the lab's HTTP request for `WEB-INF` got a 404 while AJP served the file, although the HTTP banner still showed the vulnerable version (Demonstrated [67][68]). Exposure management that lists every listening port, not only the web ports, would have found it (Inferred).
- **KEV caught up two years later and has not let go.** NVD published the CVE on 24 February 2020; KEV added it on 3 March 2022, and it is still listed in the 3 November 2026 catalog, about six years and eight months after disclosure (Confirmed [21][23]; Inferred for the arithmetic). A program that waited for the KEV listing started more than two years after the 2020 scanning (Inferred [23][43]).
- **The scores told different stories, and the configuration explains them.** 9.8 from NVD, Important or High from Apache, Important from Red Hat, Low from Ubuntu (Confirmed [1][3][21][27][29]). Rate the host, not the CVE: a stock tarball with 8009 open carries the full exposure NVD scored: a file read at minimum, and code execution where uploads land inside the application, while a distribution package with AJP off may carry no exposure (Inferred [1][28][29]).
- **Version strings mislead in both directions.** Backported packages report versions below the upstream fix line, and a banner can be edited or hidden (Confirmed [8][27][28]). Inventory should record the package and its advisory, and read `version.sh` (Inferred).
- **Embedded and bundled copies hide from service inventory.** The `tomcat-embed-core` jar and vendor-bundled Tomcats do not appear as a Tomcat service (Confirmed [26][30]). Software composition analysis and vendor advisories cover what a service scan misses (Inferred).
- **End of life turns a patch into a migration.** Upstream Tomcat 6 never got a fix, and 7.0 and 8.5 are out of support, so any Ghostcat finding on those lines is a platform upgrade, not a package update (Confirmed [15]).
- **Prioritization signals line up today.** KEV listed, SSVC active and automatable, EPSS 0.9927, and a 2026 report listing it among vulnerabilities exploited or weaponized that month: every common signal points the same way (Confirmed [22][23][25]; Reported [49]). Where all of them agree, the remaining question is exposure, which Check 3 answers.

Part 6: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the live MITRE page or the library's data files on 4 November 2026. CVE-2020-1938 is an Enterprise server flaw; the record has no ATT&CK for ICS or Mobile content. No published ATT&CK mapping exists for this CVE: the Center for Threat-Informed Defense's KEV-to-ATT&CK mapping files for ATT&CK 15.1 and 16.1 contain no entry for it (Confirmed [61]). Every technique row below is therefore this study's mapping from the advisory and the lab (Inferred), with the behavior graded where it was observed.

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1190	Exploit Public-Facing Application	Initial Access (TA0001)	Unauthenticated network access to the AJP connector: CNVD and Chaitin notices, 20 Feb 2020; Apache advisory, 24 Feb 2020; KEV listing, 3 Mar 2022; lab, 3 Nov 2026 (Demonstrated)	[1][18][19][23][67]
T1005	Data from Local System	Collection (TA0009)	Returning arbitrary files from the web application, including `WEB-INF` and `META-INF`: Apache advisory, 24 Feb 2020; Chaitin, 20 Feb 2020; lab read of `WEB-INF/web.xml`, 3 Nov 2026 (Demonstrated)	[1][18][67]
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance (TA0043)	Mass scanning checking for `/WEB-INF/web.xml`, Bad Packets, 29 Feb to 1 Mar 2020 (Reported); SSVC automatable, 6 Feb 2025; the public nuclei template	[22][43][45][57]
T1046	Network Service Discovery	Discovery (TA0007)	Fingerprinting `ajp13` on port 8009: lab `nmap -sV`, 3 Nov 2026 (defender-side, Demonstrated); DShield port 8009 traffic, February and March 2020 and October 2026 (Inferred link)	[46][47][68]
T1552.001	Unsecured Credentials: Credentials In Files	Credential Access (TA0006)	Follow-on: reading configuration files from the web application, Chaitin, 20 Feb 2020; the lab's file held no credentials	[18][67]
T1505.003	Server Software Component: Web Shell	Persistence (TA0003)	Follow-on code-execution path: an attacker-controlled file in the application processed as a JSP, Apache advisory, 24 Feb 2020; public proofs of concept that pre-placed a web-shell file, Trend Micro, 10 Mar 2020; not run in the lab	[1][18][36][65]

The names and tactics were confirmed on the live ATT&CK v20 pages (Confirmed [62]). The lab demonstrated T1190 and T1005. T1595.002 rests on reported scanning and T1046 on the lab's defender-side fingerprint. T1552.001 and T1505.003 are follow-on stages the record describes but the lab did not run. File and Directory Discovery (T1083) is left out, because the read targets known paths and lists nothing.

ATT&CK groups, software and campaigns

None. No opened source ties CVE-2020-1938 to an ATT&CK group, software or campaign object, KEV marks ransomware use as Unknown, and the one 2026 report of actor activity names no actor (Inferred [23][48][49]). No group, software or campaign page is linked.

CWE

Weakness	Name	Who assigns or relates it	Source
`NVD-CWE-Other`	None specific	NVD	[21]
`CWE-noinfo`	Insufficient information	CISA ADP container in the CVE record	[22]
CWE-269	Improper Privilege Management	GitHub advisory GHSA-c9hw-wf7x-jp9j; matches the KEV entry's name, though KEV's `cwes` field is empty	[23][26][63]
CWE-285	Improper Authorization	Red Hat	[27]
CWE-1188	Initialization of a Resource with an Insecure Default	This study's reading of the root exposure, a connector on by default on all addresses; in the library's `cwe.jsonl`, assigned by no record	[64]

This study binds no CWE as the CVE's weakness, because NVD assigns none and the other labels disagree (Inferred [21][26][27]). CWE-1188 is offered as a description of the exposure, not as an assignment (Inferred [64]). The library has no generated CWE pages; the CWE Reference covers the classes.

CAPEC

No source assigns CAPEC entries to CVE-2020-1938. These are this study's pairings, drawn from the library's `data/weaknesses/capec.jsonl` (CAPEC v3.9) (Inferred [64]):

Pattern	Name	Why it fits	Library relation
CAPEC-122	Privilege Abuse	AJP connections carry more trust than HTTP and were reachable by anyone [1]	Related CWE-269
CAPEC-639	Probe System Files	The file read of `WEB-INF` and `META-INF` [1][67]	Maps to T1552.001
CAPEC-251	Local Code Inclusion	Processing a web-application file as a JSP [1][18]	Related CWE-829
CAPEC-650	Upload a Web Shell to a Web Server	The upload-plus-JSP code-execution path [1][36]	Maps to T1505.003
CAPEC-310	Scanning for Vulnerable Software	The 2020 mass scanning [43][45]	Related CWE-200
CAPEC-541	Application Fingerprinting	The `ajp13` fingerprint and version banner [68]	Maps to T1592.002 (not bound in this study)

D3FEND countermeasures

Countermeasure	Id	Library mapping to this study's techniques (`data/attack/technique_to_d3fend.json`)	Guidance it matches	Source
Software Update	D3-SU	Not mapped to these techniques	Upgrade to 9.0.31 or later, the distribution package or `tomcat-embed-core` (Inferred pairing)	[1][26][64]
Application Configuration Hardening	D3-ACH	Not mapped to these techniques	Comment out the connector, bind it to loopback, set `secret` (Inferred pairing)	[4][7][64]
Software Inventory	D3-SWI	Not mapped to these techniques	Finding tarball, packaged, bundled and embedded copies (Inferred pairing)	[26][30][64][68]
Inbound Traffic Filtering	D3-ITF	T1190	Firewall port 8009 to the proxy only	[18][29][64]
Network Traffic Filtering	D3-NTF	T1190	Segmenting AJP onto a trusted network	[8][64]
Network Traffic Signature Analysis	D3-NTSA	T1190	Emerging Threats rules `2029533` and `2046149`; FortiGuard IPS signature	[35][55][64]
Application Protocol Command Analysis	D3-APCA	T1190	Inspecting AJP forward requests for the include attributes	[55][64]
Protocol Metadata Anomaly Detection	D3-PMAD	T1190	AJP traffic from sources other than the proxy	[64][65]
Local File Permissions	D3-LFP	T1005, T1552.001, T1505.003	Keeping secrets out of readable web-application folders (Inferred pairing)	[1][64]
File Analysis	D3-FA	T1005, T1552.001, T1505.003	Reviewing what `WEB-INF` and `META-INF` hold before rotating secrets	[64]
File Integrity Monitoring	D3-FIM	T1005, T1552.001, T1505.003	Alerting on new files in the application folders	[64]
Process Spawn Analysis	D3-PSA	T1505.003	Child processes of the Tomcat JVM after a JSP runs	[64]

The library maps D3-ITF, D3-NTF, D3-APCA, D3-NTSA and D3-PMAD to T1190; D3-LFP, D3-FA and D3-FIM to T1005, T1552.001 and T1505.003; and D3-PSA to T1505.003. D3-SU, D3-ACH and D3-SWI have library pages but no mapping to these techniques, so pairing them with this CVE is this study's reading (Confirmed for the data [64]; Inferred for the pairing).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/ghostcat-cve-2020-1938.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of its tie to CVE-2020-1938: 100 where the lab demonstrated the behavior (T1190, T1005), 75 where the record reports it (T1595.002), and 40 for the defender-side fingerprint and the follow-on stages the lab did not run (T1046, T1552.001, T1505.003). Each entry's comment names the source numbers above.

MITRE ATT&CK, CWE, CAPEC and D3FEND content is used under the terms recorded in THIRD_PARTY_NOTICES.md.

Cross-cutting themes

- **Trust that depends on reachability needs a default that enforces it.** AJP's design assumed only a proxy could connect; the pre-2020 default let anyone connect. The 9.0.31 fix enforces the assumption three ways, by turning the connector off, binding it to loopback and requiring a secret, and then adds a code check that holds even when an administrator undoes all three, as the lab's control showed (Confirmed [4][7]; Demonstrated [67]).
- **The quiet fix came first.** Tomcat 9.0.31 and 8.5.51 shipped nine days before the CNVD notice and thirteen days before Apache's disclosure, and a public proof of concept arrived the same day as the notice (Confirmed [1][19][38]; Inferred for the arithmetic). Teams that upgraded Tomcat on its release cadence were fixed before anyone knew to look; teams that waited for an advisory started behind the scanners (Inferred).
- **Configuration decides the severity.** The same code is a 9.8 on a stock tarball and Low on a distribution that never opened AJP (Confirmed [21][29]). Inventory has to record the connector state, not only the version (Inferred).
- **Logs record the request, not the intent.** The access log shows the decoy URI, not the file taken, and may show an address the client chose (Demonstrated [69]; Inferred [58]). Network signatures that see the include attributes, and source checks on port 8009, carry the detection weight (Confirmed [55]; Inferred).
- **An old CVE with no named actor is still a live one.** KEV, SSVC, EPSS, DShield and 2026 reports keep pointing at Ghostcat years after the fix, while no record names who uses it (Confirmed [22][23][25][47]; Reported [49][52]). Absence of attribution is not absence of use (Inferred).

What is overstated and what is understated

- **Overstated:** "unauthenticated remote code execution in Tomcat." By default Ghostcat is a file read; code execution needs an attacker-controlled file inside the application, which Apache, Chaitin and Trend Micro all state (Confirmed [1][18][36]).
- **Overstated:** the headline exposure counts. Figures up to a million count Tomcat or AJP fingerprints, not reachable unpatched hosts; even CNVD's own count found about 7.8 percent of the AJP hosts it saw were affected (Confirmed [19]; Reported [40][43][53]).
- **Understated:** what the read gives an attacker. `WEB-INF` and `META-INF` are where Java applications keep their configuration, and a file read there is often a credential read (Inferred [1]).

- **Understated:** the internal exposure. Port 8009 between a proxy and Tomcat sits inside networks, where lateral movement makes it reachable even when the internet cannot see it (Confirmed [36]; Inferred).

Sources

All sources were opened on 4 November 2026. The lab captures are not published; the screenshots in Part 3 render them.

#	Source	URL	Opened	Grade
1	Apache Tomcat, Apache Tomcat 9.x vulnerabilities (CVE-2020-1938 under "Fixed in Apache Tomcat 9.0.31")	tomcat.apache.org/security-9.html	2026-11-04	Confirmed
2	Apache Tomcat, Apache Tomcat 8.x vulnerabilities (8.5.51 entry; end-of-life note)	tomcat.apache.org/security-8.html	2026-11-04	Confirmed
3	Apache Tomcat, Apache Tomcat 7.x vulnerabilities (7.0.100 entry)	tomcat.apache.org/security-7.html	2026-11-04	Confirmed
4	Apache Tomcat 9.0 changelog, 9.0.31 section	tomcat.apache.org/tomcat-9.0-doc/changelog.html	2026-11-04	Confirmed
5	Apache Tomcat 8.5 changelog, 8.5.51 section	tomcat.apache.org/tomcat-8.5-doc/changelog.html	2026-11-04	Confirmed
6	Apache Tomcat 7.0 changelog, 7.0.100 section	tomcat.apache.org/tomcat-7.0-doc/changelog.html	2026-11-04	Confirmed
7	Apache Tomcat 9.0, The AJP Connector reference	tomcat.apache.org/tomcat-9.0-doc/config/ajp.html	2026-11-04	Confirmed
8	Apache Tomcat 9.0, Security Considerations	tomcat.apache.org/tomcat-9.0-doc/security-howto.html	2026-11-04	Confirmed
9	Apache Tomcat 9.0, Windows Service How-To	tomcat.apache.org/tomcat-9.0-doc/windows-service-howto.html	2026-11-04	Confirmed
10	Apache Tomcat 9.0, RUNNING.txt	tomcat.apache.org/tomcat-9.0-doc/RUNNING.txt	2026-11-04	Confirmed
11	Apache Tomcat 9.0, The Valve Component (AccessLogValve pattern codes)	tomcat.apache.org/tomcat-9.0-doc/config/valve.html	2026-11-04	Confirmed
12	apache/tomcat commit `64fa5b99` (21 Jan 2020), the AJP attribute check	github.com/apache/tomcat/commit/64fa5b99442589ef0bf2a7fcd71ad2bc68b35fad	2026-11-04	Confirmed
13	apache/tomcat 9.0.x fix commits `0e8a50f0`, `9ac90532`, `7a1406a3`, `49ad3f95`	github.com/apache/tomcat/commit/0e8a50f0a5958744bea1fd6768c862e04d3b7e75	2026-11-04	Confirmed
14	apache/tomcat `conf/server.xml` at tags 9.0.30 and 9.0.31	github.com/apache/tomcat/blob/9.0.31/conf/server.xml	2026-11-04	Confirmed
15	Apache Tomcat end-of-life notices for 8.5.x, 7.0.x and 6.0.x	tomcat.apache.org/tomcat-85-eol.html	2026-11-04	Confirmed
16	Apache HTTP Server 2.4, mod_proxy_ajp	httpd.apache.org/docs/2.4/mod/mod_proxy_ajp.html	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
17	Apache Tomcat Connectors, workers.properties reference (mod_jk)	tomcat.apache.org/connectors-doc/reference/workers.html	2026-11-04	Confirmed
18	Chaitin Tech, Ghostcat disclosure page (Internet Archive copy of 2 Mar 2020; live page returns 404)	web.archive.org/web/20200302134620/https://www.chaitin.cn/en/ghostcat	2026-11-04	Confirmed
19	CNVD, security notice CNTA-2020-0004 (20 Feb 2020; Internet Archive copy of 1 Mar 2020)	web.archive.org/web/20200301091213/https://www.cnvd.org.cn/webinfo/show/5415	2026-11-04	Confirmed
20	CNVD, flaw record CNVD-2020-10487 (Internet Archive copy of 9 May 2020)	web.archive.org/web/20200509021602/https://www.cnvd.org.cn/flaw/show/CNVD-2020-10487	2026-11-04	Confirmed
21	NVD, CVE-2020-1938 (detail page and API 2.0)	nvd.nist.gov/vuln/detail/CVE-2020-1938	2026-11-04	Confirmed
22	CVE record CVE-2020-1938 (CNA apache; CISA ADP Vulnrichment), CVE Services API	cveawg.mitre.org/api/cve/CVE-2020-1938	2026-11-04	Confirmed
23	CISA, Known Exploited Vulnerabilities catalog JSON feed (catalog 2026.11.03)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-04	Confirmed
24	CISA, CISA Adds 95 Known Exploited Vulnerabilities to Catalog (3 Mar 2022)	cisa.gov/news-events/alerts/2022/03/03/cisa-adds-95-known-exploited-vulnerabilities-catalog	2026-11-04	Confirmed
25	FIRST, EPSS API for CVE-2020-1938 (score date 3 Nov 2026)	api.first.org/data/v1/epss?cve=CVE-2020-1938	2026-11-04	Confirmed
26	GitHub Advisory Database, GHSA-c9hw-wf7x-jp9j (published 15 Jun 2020)	github.com/advisories/GHSA-c9hw-wf7x-jp9j	2026-11-04	Confirmed
27	Red Hat, security data API for CVE-2020-1938 (rating, CWE, errata)	access.redhat.com/hydra/rest/securitydata/cve/CVE-2020-1938.json	2026-11-04	Confirmed
28	Debian security tracker, CVE-2020-1938	security-tracker.debian.org/tracker/CVE-2020-1938	2026-11-04	Confirmed
29	Ubuntu, CVE-2020-1938	ubuntu.com/security/CVE-2020-1938	2026-11-04	Confirmed
30	Oracle, Critical Patch Update Advisory, July 2020	oracle.com/security-alerts/cpujul2020.html	2026-11-04	Confirmed
31	Oracle, Critical Patch Update Advisory, October 2020	oracle.com/security-alerts/cpuoct2020.html	2026-11-04	Confirmed
32	Oxygen XML, security advisory for CVE-2020-1938 (4 Mar 2020, revised 7 Apr 2020)	oxygenxml.com/security/advisory/CVE-2020-1938.html	2026-11-04	Confirmed
33	Tenable, CVE-2020-1938: Ghostcat (Satnam Narang, 21 Feb 2020, updated 23 Feb 2020)	tenable.com/blog/cve-2020-1938-ghostcat-apache-tomcat-ajp-file-readinclusion-vulnerability-cnvd-2020-10487	2026-11-04	Confirmed for its own write-up; Reported for the Tomcat 6 and workaround claims
34	Tenable, Nessus plugin 134862 (published 24 Mar 2020)	tenable.com/plugins/nessus/134862	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
35	Fortinet FortiGuard, Threat Signal Report 3404 (28 Feb 2020)	fortiguard.fortinet.com/threat-signal-report/3404	2026-11-04	Confirmed
36	Trend Micro, Busting Ghostcat (Magno Logan, 10 Mar 2020)	trendmicro.com/en_us/research/20/c/busting-ghostcat-...	2026-11-04	Confirmed for its analysis; Reported for the rule numbers
37	DIVD CSIRT, GhostCat (22 Feb 2020)	csirt.divd.nl/2020/02/22/Ghostcat/	2026-11-04	Reported
38	Exploit-DB, EDB-48143 (20 Feb 2020)	exploit-db.com/exploits/48143	2026-11-04	Demonstrated (public proof of concept exists; not reproduced here)
39	Rapid7 Metasploit Framework, `modules/auxiliary/admin/http/tomcat_ghostcat.rb`	github.com/rapid7/metasploit-framework/blob/master/modules/auxiliary/admin/http/tomcat_ghostcat.rb	2026-11-04	Confirmed
40	AppCheck, Ghostcat exposure post (27 Feb 2020)	appcheck-ng.com/?p=9531	2026-11-04	Reported
41	The Hacker News, Ghostcat (28 Feb 2020)	thehackernews.com/2020/02/ghostcat-new-high-risk-vulnerability.html	2026-11-04	Reported
42	SecurityWeek, Apache Tomcat Affected by Serious Ghostcat Vulnerability (28 Feb 2020)	securityweek.com/apache-tomcat-affected-serious-ghostcat-vulnerability/	2026-11-04	Reported
43	BleepingComputer, active scans for Ghostcat (2 Mar 2020)	bleepingcomputer.com/news/security/active-scans-for-apache-tomcat-ghostcat-vulnerability-detected-patch-now/	2026-11-04	Reported
44	Security Affairs, Ghostcat mass scanning (3 Mar 2020)	securityaffairs.com/98830/hacking/ghostcat-mass-scanning.html	2026-11-04	Reported
45	SecurityWeek, hackers scanning for Ghostcat (5 Mar 2020)	securityweek.com/hackers-scanning-apache-tomcat-servers-vulnerable-ghostcat-attacks/	2026-11-04	Reported
46	SANS ISC DShield, port 8009 history, 1 Feb to 31 Mar 2020 (API)	isc.sans.edu/api/porthistory/8009/2020-02-01/2020-03-31?json	2026-11-04	Confirmed (data); Inferred (link to Ghostcat)
47	SANS ISC DShield, port 8009 history, 1 Oct to 2 Nov 2026 (API)	isc.sans.edu/api/porthistory/8009/2026-10-01/2026-11-02?json	2026-11-04	Confirmed (data)
48	Palo Alto Networks Unit 42, network attack trends, winter 2020	unit42.paloaltonetworks.com/network-attack-trends-winter-2020/	2026-11-04	Confirmed (opened); Inferred (absence)
49	Recorded Future, September 2026 CVE Landscape	recordedfuture.com/blog/september-2026-cve-landscape	2026-11-04	Reported
50	Pentest-Tools.com, most exploited vulnerabilities in 2022 (updated 10 Jun 2024)	pentest-tools.com/blog/top-most-exploited-vulnerabilities-2022	2026-11-04	Reported
51	Edgescan, 2024 Vulnerability Statistics Report (9th edition)	edgescan.com/wp-content/uploads/2025/04/2024-Vulnerability-Statistics-Report.pdf	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
52	OffSeq, Connection Is Not an Exploit (Mirage honeypot report, dated 21 Jun 2026)	offseq.com/en/research/connection-is-not-an-exploit/	2026-11-04	Reported
53	DEV Community, the AJP connector on 8009 is still listening (ZoomEye query of 25 Oct 2026)	dev.to/kozhevniko/the-ajp-connector-on-8009-is-still-listening-and-it-is-not-a-web-port-41i	2026-11-04	Reported
54	CIRCL Vulnerability-Lookup, sightings of CVE-2020-1938 (API)	vulnerability.circl.lu/api/sighting/?vuln_id=CVE-2020-1938&per_page=100	2026-11-04	Confirmed (data); Inferred (reading)
55	Emerging Threats Open, `emerging-exploit.rules` for Suricata 7.0.3 (rules 2029533 and 2046149)	rules.emergingthreats.net/open/suricata-7.0.3/rules/emerging-exploit.rules	2026-11-04	Confirmed
56	Nmap NSE, `ajp-headers` script	nmap.org/nsedoc/scripts/ajp-headers.html	2026-11-04	Confirmed
57	ProjectDiscovery nuclei-templates, `network/cves/2020/CVE-2020-1938.yaml` at commit `91362b7d`	raw.githubusercontent.com/projectdiscovery/nuclei-templates/91362b7d.../CVE-2020-1938.yaml	2026-11-04	Confirmed
58	vulhub, `tomcat/CVE-2020-1938/poc.py` at commit `760e171d` (24 Sep 2024)	github.com/vulhub/vulhub/commit/760e171de8d0da47f670a1301435eced83b5624c	2026-11-04	Confirmed
59	vulhub, Tomcat CVE-2020-1938 environment README	github.com/vulhub/vulhub/tree/master/tomcat/CVE-2020-1938	2026-11-04	Reported
60	Docker Hub, tag pages for `vulhub/tomcat:9.0.30` and `tomcat:9.0.31` (API)	hub.docker.com/v2/repositories/vulhub/tomcat/tags/9.0.30	2026-11-04	Confirmed
61	Center for Threat-Informed Defense, Mappings Explorer KEV-to-ATT&CK mappings (ATT&CK 16.1, KEV 07.28.2025; and ATT&CK 15.1)	raw.githubusercontent.com/center-for-threat-informed-defense/mappings-explorer/main/mappings/kev/...	2026-11-04	Confirmed (absence)
62	MITRE ATT&CK v20, technique pages T1190, T1005, T1552.001, T1505.003, T1595.002 and T1046	attack.mitre.org/techniques/T1190/	2026-11-04	Confirmed
63	MITRE CWE, CWE-269 Improper Privilege Management	cwe.mitre.org/data/definitions/269.html	2026-11-04	Confirmed
64	TeamStarWolf library data: `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `navigator/library-layers/`, and the generated pages under `mitre/`	In this repository	2026-11-04	Confirmed
65	Lab plan `plan.json` for CVE-2020-1938 (image choice, executed deviations, risks, detection notes)	Lab capture (not published)	2026-11-04	Demonstrated for what ran; Inferred for plan notes
66	Lab capture `01-setup.txt`, 3 Nov 2026	Lab capture (not published); screenshot in Part 3	2026-11-04	Demonstrated
67	Lab capture `02-test.txt`, 3 Nov 2026	Lab capture (not published)	2026-11-04	Demonstrated

#	Source	URL	Opened	Grade
68	Lab capture `03-exposure.txt`, 3 Nov 2026	Lab capture (not published); screenshot in Part 3	2026-11-04	Demonstrated
69	Lab capture `04-mitigation.txt`, 3 Nov 2026	Lab capture (not published); screenshot in Part 3	2026-11-04	Demonstrated
70	Lab capture `05-cleanup.txt`, 3 Nov 2026	Lab capture (not published); screenshot in Part 3	2026-11-04	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Triage a CVE
- Web Application Security Reference
- Other vulnerability studies: Log4Shell (CVE-2021-44228), another Java web-tier flaw in KEV; CVE-2026-98432 Linux TCP use-after-free
- Techniques: T1190 Exploit Public-Facing Application, T1005 Data from Local System, T1595.002 Vulnerability Scanning, T1046 Network Service Discovery, T1552.001 Credentials In Files, T1505.003 Web Shell
- CAPEC: CAPEC-122, CAPEC-639, CAPEC-251, CAPEC-650, CAPEC-310, CAPEC-541
- D3FEND: all countermeasures
- Navigator layers, including this study's layer, ghostcat-cve-2020-1938.json